

케이뱅크플러스 오픈뱅킹 API 게이트웨이 API 설계서

문서번호	KBP-2027-API-114
작성일	2026년 12월 18일
상위 문서	KBP-2027-SOW-114 과업지시서 3.1 · 3.2 · 3.3
적용 범위	대외 공개 규격 v2. 계정계 내부 전문은 대상이 아니다.

1. 공통 규격

항목	값
기준 주소	https://openapi.kbplus.example/v2
전문 형식	JSON, UTF-8
일시 표기	ISO 8601, KST 고정
필수 헤더	X-KBP-Org-Code, X-KBP-Trace-Id
커넥션 타임아웃	2초
읽기 타임아웃	5초
응답 전문 최대 크기	256KB
페이지 크기	기본 50건, 최대 500건

X-KBP-Trace-Id 는 기관이 채번하여 보내고, 게이트웨이는 이 값을 기록에 그대로 남긴다. 기관이 보내지 않으면 게이트웨이가 채번한다. 장애 조사 시 기관과 당행이 같은 값을 가지고 이야기하기 위한 규칙이다.

게이트웨이 계층 구성

대외 채널 계층 제휴 기관 호출 수신 · 상호 TLS 종단
게이트웨이 계층 라우팅 · 인증 · 유량 제어 · 호출 기록
업무 어댑터 계층 대외 전문과 내부 전문 변환 · 맥등 키 처리
원장 연계 계층 계정계 전문 연계 구간 (본 사업 변경 대상 아님)

그림 1 게이트웨이 계층 구성

2. 엔드포인트 목록

경로	메서드	설명	스코프	유량 가중치
/v2/accounts/balance	GET	잔액 조회	accounts.read	1
/v2/accounts/transactions	GET	거래 내역 조회	accounts.read	3
/v2/accounts/real-name	GET	예금주 조회	accounts.read	2
/v2/transfers/withdrawal	POST	출금 이체	transfers.write	5
/v2/transfers/deposit	POST	입금 이체	transfers.write	5
/v2/consents	POST	사용자 동의 등록	consents.write	1
/v2/consents/{consentId}	DELETE	사용자 동의 철회	consents.write	1
/v2/cards/bills	GET	카드 청구 정보	cards.read	3
/v2/loans/summary	GET	대출 잔액 요약	loans.read	2
/v2/health	GET	상태 확인 (인증 불필요)	-	0

유량 가중치는 제5장의 한도를 소모하는 크기다. 출금 이체 한 건은 잔액 조회 다섯 건과 같은 몫을 쓴다.

3. 인증 방식

기관 자체 업무는 클라이언트 자격증명 방식으로, 사용자 계좌에 접근하는 업무는 인가 코드 방식으로 토큰을 받는다. 두 경우 모두 기관 인증서를 이용한 상호 TLS 위에서만 요청을 받는다. 인증서 규격과 보안 요건은 「보안 요구사항서」를 따른다.

사용자 계좌 접근 인증 흐름

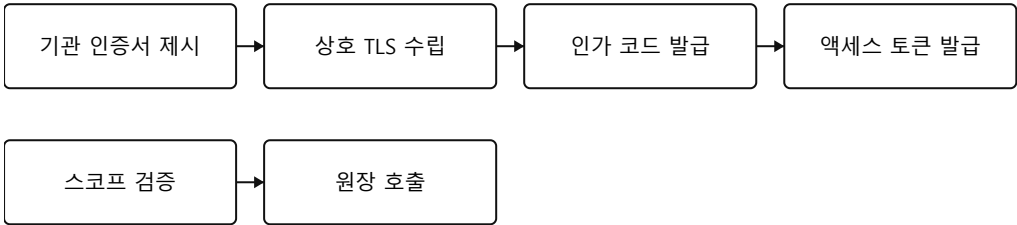


그림 2 사용자 동의 기반 인증 흐름

항목	값	비고
액세스 토큰 유효시간	1,800초	만료 후 재발급
갱신 토큰 유효시간	90일	사용자 동의 갱신 주기와 맞춘다
인가 코드 유효시간	300초	1회용
토큰 폐기 전파	요청 즉시	전 노드 반영은 요구사항 정의서 OB-F-13

3.1 권한 범위(스코프)

스코프	허용 범위	동의 필요
accounts.read	잔액·거래내역·예금주 조회	필요
transfers.write	출금·입금 이체	필요
consents.write	동의 등록·철회	필요
cards.read	카드 청구 정보 조회	필요
loans.read	대출 잔액 조회	필요
org.stats	기관 자기 사용량 조회	불필요

4. 오류 코드

오류 응답은 code, message, traceId 세 항목을 반드시 담는다. message 는 사람이 읽는 설명이며 기관은 분기 판단에 쓰지 않는다. 분기는 code 로만 한다.

코드	HTTP	의미	기관 조치
A0011	400	필수 항목 누락 또는 형식 오류	전문 확인 후 재구성
A0021	401	토큰 만료 또는 서명 불일치	토큰 재발급 후 재호출
A0031	403	권한 범위 초과	사용자 동의 범위 확인
A0044	404	계좌 없음 또는 해지 계좌	재호출 금지
A0052	409	중복 거래	역등 키 확인 후 결과 조회
A0067	429	유량 한도 초과	Retry-After 만큼 대기
A0088	502	원장 응답 없음	조회로 결과 확인 후 판단
A0099	503	정기 점검 중	점검 창 이후 재개

5. 유량 제어

기관 단위 토큰 버킷으로 제어한다. 버킷은 초 단위로 채우며 순간 물림을 흡수할 수 있게 버스트를 따로 둔다. 한도를 넘긴 호출은 백엔드로 넘기지 않고 게이트웨이에서 끊는다.

등급	초당 한도	버스트	일 한도	적용 대상
표준	320	480	200만 건	신규 및 일반 제휴 기관
우대	640	960	600만 건	직전 3개월 일 평균 100만 건 이상
특별	1,200	1,800	1,500만 건	발주사 승인 건에 한함

신규 기관은 표준 등급으로 시작하며 기본 한도는 초당 320건이다. 한도 초과 응답에는 Retry-After 헤더를 60초로 실어 보낸다. 등급 상향은 기관 신청 후 발주사 승인으로 이루어지며, 반영 기한은 「요구사항 정의서」 OB-F-23 에 있다.

6. 맥등 처리와 재시도

- 이체 요청은 X-KBP-Idem-Key 헤더를 필수로 받는다.
- 같은 맥등 키의 재요청은 최초 처리 결과를 그대로 돌려준다.
- 맥등 키는 72시간 보관하며 그 뒤의 재사용은 새 거래로 본다.
- 이체는 실패해도 자동 재시도하지 않는다. 결과 조회로 확인한 뒤 기관이 판단한다.
- 조회성 호출의 재시도 간격은 1초, 2초, 4초로 하고 3회에서 멈춘다.

7. 버전 정책

대외 규격은 v1 과 v2 만 둔다. v1 은 이전 기간 동안만 함께 제공하고 종료일 이후에는 A0099 로 회신한다. 규격 변경은 개발자 포털 공지를 거치며, 필드 추가는 하위 호환으로 보고 필드 삭제와 의미 변경은 버전을 올린다.